

Familia 3 — Datos sensibles y privacidad

Documento profundo de referencia · Para uso del formador Sesión "Seguridad y buenas prácticas en desarrollo con IA" · AI PM Pro · The Hero Camp

Índice

1. Por qué esta familia es la más regulatoriamente cara
 2. Definiciones precisas: qué cuenta como "dato sensible"
 3. Los tres vectores principales donde se escapan los datos
 4. Mecanismo: cómo el agente IA multiplica la superficie de fuga
 5. Magnitud: los datos que hay que conocer de memoria
 6. Severidad: tres ejes para clasificar
 7. Obligaciones RGPD que todo PM debe conocer
 8. A quién afecta: los afectados son los usuarios, no la empresa
 9. Casos reales documentados
 10. El factor agente IA: la trampa del "solo estoy probando"
 11. Lo que el PM senior tiene que interiorizar
 12. Fuentes
-

1. Por qué esta familia es la más regulatoriamente cara

Si la Familia 1 (credenciales) es la más mediática y la Familia 2 (bases de datos) es la más silenciosamente grave, la Familia 3 es la más **económicamente cara a medio plazo**. Y la razón no es la explotación técnica sino la regulatoria.

Cuando una clave de Gemini se filtra, pierdes dinero directamente en tu factura. Cuando una base de datos se expone, pierdes datos. Pero cuando esos datos son datos personales, entras en un dominio donde el coste no lo marca el atacante, lo marca el regulador. En 2025, las autoridades de protección de datos europeas emitieron **aproximadamente 1.200 millones de euros en multas RGPD**, y el acumulado desde 2018 alcanza los **7.100 millones de euros**. La multa más grande hasta la fecha sigue siendo la de 1.200 millones contra Meta en 2023; la más grande de 2025 fue de 530 millones contra TikTok por transferencias internacionales de datos. Y solo en 2025, **el número medio de notificaciones diarias de brechas de datos personales en Europa superó las 400 por primera vez desde 2018**, un 22% más que en 2024.

Estos datos importan por una razón específica para el perfil del curso. Un PM Senior que construye productos con Claude Code está tocando datos personales desde el día uno: un formulario que captura emails es ya un tratamiento de datos personales bajo el RGPD. Y el reglamento no distingue entre "startup de cuatro personas validando una idea" y "multinacional con 50.000 empleados". **Las obligaciones son las mismas desde el primer email recogido**. Lo que cambia es la probabilidad de que te inspeccionen, no la obligación de cumplir.

Para esta sesión, esta familia tiene un rol específico: es la que **transforma el discurso técnico en discurso de negocio**. Cuando el PM entiende que una configuración incorrecta de logs puede derivar en una multa de porcentaje de facturación global, deja de ver la seguridad como un tema de ingeniería y empieza a verla

como una decisión de producto con impacto económico directo. Ese cambio de perspectiva es el que justifica por sí solo el tiempo que invertimos en esta familia.

2. Definiciones precisas: qué cuenta como "dato sensible"

Una de las confusiones más extendidas entre PMs es creer que "dato sensible" se refiere solo a contraseñas o tarjetas de crédito. El marco del RGPD es mucho más amplio y conviene manejarlo con precisión.

Datos personales. Cualquier información relativa a una persona física identificada o identificable. Incluye **nombres, emails, teléfonos, direcciones, identificadores de usuario, IPs, cookies de seguimiento, historial de uso individualizado, mensajes, fotos, audio, localización**. Un email suelto sin nombre es un dato personal. Una IP sin nombre es un dato personal. Un identificador interno tipo "user_id = 12345" es un dato personal si se puede cruzar con otra información para identificar a la persona.

La implicación práctica: **cualquier tabla con campos como email, user_id, ip_address, session_id contiene datos personales**. No es necesario que tenga nombre y apellidos. Esto pilla desprevenidos a muchos PMs que creen que "como solo guardo emails, no es para tanto".

Categorías especiales de datos. El RGPD eleva la protección para ciertos tipos: datos de salud, biométricos, genéticos, orientación sexual, opiniones políticas, religión, afiliación sindical, datos de menores. Su tratamiento requiere base jurídica reforzada y su exposición en una brecha multiplica la gravedad regulatoria. Muchos productos recogen estos datos sin darse cuenta: una app de fitness que pide edad y peso puede estar tratando datos de salud; un formulario con "pronombres preferidos" puede estar tratando orientación/identidad; un chat entre usuarios puede contener cualquier cosa.

Datos confidenciales empresariales. No son datos personales pero su exposición tiene consecuencias. Código fuente propietario, planes estratégicos, datos financieros no públicos, propiedad intelectual. El caso Samsung que veremos en la sección de casos reales entra aquí: los ingenieros no filtraron datos personales, filtraron código propietario.

Datos técnicos con potencial sensible. Logs que parecen inocuos pero contienen PII, trazas de API calls con payload completo, mensajes de error con datos reales del usuario, caché de sesiones. Esta es la categoría más olvidada y donde más fácilmente se cuelan los datos sensibles en sitios donde nadie espera que estén.

Un marco mental útil para los PMs: **si un dato, al filtrarse, permitiría a un tercero identificar a un usuario, hacerle daño, o molestarle, es un dato sensible**. La pregunta útil no es "¿este campo es personal?", sino "si este archivo se publica mañana en Reddit, ¿tengo un problema?".

3. Los tres vectores principales donde se escapan los datos

Los datos sensibles no se fugan principalmente por ataques sofisticados; se fugan por tres vectores mundanos que los PMs subestiman sistemáticamente. Conviene separarlos porque cada uno tiene su lógica de prevención.

Vector 1: datos personales en lugares donde nadie los busca. Logs de aplicación que imprimen el objeto completo del usuario cuando algo falla. Respuestas de API que devuelven más campos de los necesarios (incluyendo timestamps internos, campos de debug, datos de sesión). Endpoints de administración olvidados

que devuelven tablas completas. Mensajes de error que exponen información del sistema. El agente IA tiende a añadir `console.log(user)` o similar como forma rápida de depurar, y ese log acaba en producción.

Vector 2: datos reales en entornos de no-producción. Es el más subestimado y quizá el más grave estadísticamente. Un estudio de Tonic.ai con 1.000 desarrolladores encontró que **el 29% de las empresas usan datos de producción sin proteger (datos reales de clientes) en entornos de pruebas**. Y **el 45% de los encuestados reportó que su empresa había sufrido una brecha importante en los últimos cinco años debido en parte al uso de datos en entornos inseguros**. El sector más afectado: servicios financieros con un 60%.

Con un agente IA, este vector se agrava. El agente, al intentar resolver un bug, tiende a pedir "un ejemplo de los datos reales para reproducir el problema". Si se le da acceso al dump de producción, los datos acaban en sitios que nadie controla: archivos locales del desarrollador, contexto del LLM, pasted en un ticket, guardados en un .txt de referencia.

Vector 3: datos sensibles enviados a LLMs externos (shadow AI). Este es el vector más nuevo y el que está creciendo más rápido. Se da cuando los empleados o desarrolladores pegan datos sensibles en ChatGPT, Claude web, Gemini o similares, pensando que "solo es para consultar algo rápido". Según IBM 2025, **el 20% de las brechas de datos en 2025 estuvieron relacionadas con shadow AI** (uso no autorizado de herramientas IA por empleados). Las brechas relacionadas con shadow AI cuestan de media **670.000 dólares más** que las brechas estándar, y afectan PII de clientes en el **65% de los casos** frente al 53% de la media global.

Crítico: el 97% de las brechas relacionadas con IA ocurrieron en entornos que carecían de controles de acceso adecuados para IA. Y el 63% de las organizaciones que sufrieron brechas no tenían políticas formales de gobernanza de IA.

4. Mecanismo: cómo el agente IA multiplica la superficie de fuga

La cadena de eventos con agentes es distinta de las familias anteriores porque aquí el agente no "filtra sin querer"; aquí el agente **se lleva activamente los datos a sitios distintos**.

Paso 1: El PM necesita resolver algo con datos reales. "¿Por qué falla este usuario específico?", "¿cómo puedo replicar este bug?", "¿qué estructura tienen exactamente nuestros datos?". Son preguntas legítimas de trabajo.

Paso 2: Para responderlas, se extrae un snapshot de datos reales. Puede ser un dump de la base de datos, una consulta ad-hoc, un export a CSV. Estos datos son personales. En el entorno de producción tenían protecciones; a partir de este momento, no.

Paso 3: Los datos viajan. Al laptop del desarrollador. A un archivo temporal. A un canal de Slack de debug. A un ticket de soporte interno. A una conversación con el agente IA, que los procesa para ayudar a resolver el problema. A veces a la caché del IDE. A veces a los logs del terminal.

Paso 4: Los datos quedan. Cuando el problema se resuelve, nadie vuelve a limpiar los datos. El archivo sigue en el laptop. El canal de Slack sigue con la conversación. El agente IA tiene el contexto en su historial. La base de datos "de pruebas" sigue poblada con datos reales.

Paso 5: La fuga ocurre mucho después. El laptop se pierde o lo roban. El repositorio privado se expone accidentalmente. El agente IA proveedor es comprometido. La base de datos de staging tenía una configuración de red distinta y es accesible desde internet. **Los datos se filtran sin que nadie recuerde ya por qué estaban ahí.**

Diferencia clave con las otras familias: en Familia 1 y 2 el agente IA es vehículo o amplificador, pero el dato ya estaba "en casa". En Familia 3, el agente IA **mueve activamente el dato a sitios más expuestos**. Cada vez que un desarrollador pega un trozo de datos reales en el contexto del LLM para depurar, ha creado una nueva copia del dato en un lugar que no controla.

El caso especial de los MCPs. Un servidor MCP (Model Context Protocol) conectado a una base de datos da al agente IA acceso directo a los datos. Si esa conexión tiene permisos amplios, el agente puede leer cualquier tabla. Y si el agente es manipulado por prompt injection (como vimos en Familia 2), puede exfiltrar los datos. El MCP de Supabase documentado por General Analysis es el caso canónico.

5. Magnitud: los datos que hay que conocer de memoria

Multas y volumen regulatorio europeo:

- **1.200 millones de euros** en multas RGPD en 2025, en línea con 2024.
- **7.100 millones de euros acumulados** en multas RGPD desde la entrada en vigor del reglamento en mayo de 2018.
- **443 notificaciones diarias de brechas de datos** en Europa de media en 2025, un 22% más que en 2024. Es la primera vez desde 2018 que se superan las 400 diarias.
- **Nueve de las diez mayores multas RGPD de la historia** han sido contra empresas tecnológicas y de redes sociales.
- **530 millones de euros:** la multa más grande de 2025, impuesta por Irlanda a TikTok por transferencias internacionales ilegales.
- **1.200 millones de euros:** multa récord histórica, contra Meta en 2023 por transferencias de datos a Estados Unidos.

Datos reales en entornos de pruebas:

- **El 29% de las empresas usan datos de producción sin proteger en entornos de pruebas** (estudio Tonic.ai con 1.000 desarrolladores).
- **El 45% de los encuestados** reportó que su empresa había sufrido una brecha importante en los últimos cinco años debido en parte al uso de datos en entornos inseguros.
- Sectores más afectados: servicios financieros (60%), construcción (57%), educación (54%), alimentación (53%), despachos de abogados (53%).
- Solo el **50% de las empresas** usa datos de-identificados o sintéticos en testing.

Shadow AI y fugas a LLMs externos:

- **El 20% de todas las brechas de datos en 2025** estuvieron relacionadas con shadow AI (IBM Cost of a Data Breach 2025).
- **670.000 dólares adicionales** de coste medio por brecha cuando hay shadow AI involucrada (IBM).
- **El 65% de incidentes de shadow AI** involucran compromiso de PII de clientes, frente al 53% de la media.

- **El 62% de incidentes de shadow AI** afectan datos en múltiples entornos, complicando detección y contención.
- **El 63% de organizaciones que sufrieron brechas** no tenían políticas formales de gobernanza de IA.
- **El 97% de las brechas relacionadas con IA** ocurrieron en entornos sin controles de acceso adecuados para IA.
- **El 83% de las organizaciones** no tienen controles técnicos para detectar o prevenir que empleados suban datos confidenciales a plataformas de IA (investigación de Kiteworks).
- **El 27% de organizaciones** reportan que más del 30% de los datos que procesa su IA contienen información privada.

Costes económicos (IBM Cost of a Data Breach 2025):

- **4,44 millones de dólares:** coste medio global de una brecha.
- **10,22 millones:** coste medio en Estados Unidos, récord histórico.
- **7,42 millones:** coste medio en sanidad (14 años consecutivos liderando).
- **5,56 millones** en servicios financieros.
- **PII de clientes** es el tipo de dato más comprometido en 2025, presente en el 53% de brechas.
- **178 dólares por registro:** coste medio por exposición de propiedad intelectual, el tipo de dato más caro.

Tiempo:

- **241 días** de media para identificar y contener una brecha en 2025 (el menor en casi una década).
- **276 días** cuando afecta a múltiples entornos.
- **247 días** en brechas relacionadas con shadow AI (en el rango de cloud privado).
- **276 días** en brechas que se extienden por cloud público, cloud privado y on-premises simultáneamente.
- **72 horas** es el plazo de notificación obligatoria tras tener constancia de una brecha bajo RGPD (probable ampliación a 96 horas con el Digital Omnibus).

6. Severidad: tres ejes para clasificar

Eje 1 · Impacto económico directo

A diferencia de las credenciales, aquí el impacto económico directo suele ser menor, pero entran factores adicionales.

Crítico: exposición de bases de datos enteras con información de pago, credenciales reutilizables, datos de identificación oficial. Venta directa en mercados negros, fraude financiero posterior, suplantación de identidad.

Alto: exposición de datos que permiten fraude posterior. Emails verificados combinados con contraseñas (aunque estén hasheadas, las hash quebrables tienen valor), información personal que permite phishing dirigido de alto valor.

Medio: exposición de datos de uso o interacción que revelan patrones aprovechables. Historial de búsquedas, conversaciones internas, información estratégica indirecta.

Bajo: exposición de datos agregados o con valor limitado en mercados negros.

Eje 2 · Impacto regulatorio y legal

Aquí es donde la Familia 3 cobra su peso máximo. Este es el eje donde cualquier clasificación se desplaza un nivel hacia arriba cuando hay datos personales involucrados.

Crítico: exposición de categorías especiales de datos (salud, biométricos, orientación sexual, datos de menores). Multas potenciales de hasta el 4% de la facturación anual global o 20 millones de euros. Obligación de notificación en 72 horas a la autoridad de protección de datos. Posible obligación de notificación individual a cada afectado. Potencial exposición penal para directivos en casos graves.

Crítico también: brechas que implican transferencias internacionales ilegales de datos (ver multa de 530 millones a TikTok). El marco post-Schrems II sigue siendo problemático; cualquier transferencia a terceros países sin garantías adecuadas es un riesgo regulatorio.

Alto: exposición de datos personales "ordinarios" (emails, nombres, teléfonos). Multa potencial de hasta el 2% de facturación o 10 millones de euros. Obligación de notificación.

Medio: exposición de datos técnicos que podrían ser identificables con esfuerzo de reidentificación.

Bajo: exposición de datos completamente anónimos.

Un dato que conviene tener a mano: desde septiembre de 2025, el Tribunal de Justicia de la UE confirmó que el **"daño no patrimonial" causado por una brecha RGPD puede incluir miedo o ansiedad y puede ser base para compensación individual**. Esto abre la puerta a demandas individuales de afectados, adicionales a las multas regulatorias.

Eje 3 · Impacto reputacional y de negocio

Crítico: brechas notificadas públicamente que afectan a miles o millones de usuarios. Cobertura en prensa general, no solo técnica. Pérdida masiva de confianza, abandono de usuarios, impacto en cotización bursátil si aplica.

Alto: brechas que circulan en comunidades profesionales, foros de seguridad, Twitter técnico. El daño es más lento pero persistente.

Medio: brechas descubiertas por un cliente o socio específico. Ruptura de relación comercial, potencial pleito individual.

Bajo: brechas detectadas internamente y resueltas antes de exposición pública.

7. Obligaciones RGPD que todo PM debe conocer

Esta sección es el contenido más "aburrido" de la familia pero probablemente el más útil en términos prácticos. Un PM Senior que desconoce estas obligaciones está expuesto personalmente y expone a su empresa.

Obligación 1: Base jurídica para el tratamiento. No puedes recoger datos personales "porque sí". Necesitas una base jurídica: consentimiento explícito, ejecución de contrato, obligación legal, interés legítimo (con test de ponderación), interés vital, o misión pública. Para la mayoría de productos, el consentimiento o el interés

legítimo son las vías principales. Esto implica que **cualquier formulario que capture datos debe tener un texto claro explicando qué se recoge, para qué, y cuál es la base jurídica.**

Obligación 2: Minimización. Solo puedes recoger los datos estrictamente necesarios para la finalidad declarada. Un formulario de registro para una newsletter no debería pedir fecha de nacimiento si no la usas. Cada campo extra es una obligación más y una superficie de exposición más.

Obligación 3: Notificación de brechas en 72 horas. Desde que tienes constancia razonable de una brecha de seguridad que afecte a datos personales, tienes 72 horas para notificar a la autoridad de protección de datos competente (en España, la AEPD). Si la brecha supone un alto riesgo para los derechos de los afectados, también hay que notificarles a ellos individualmente. **El reloj empieza desde la constancia, no desde la ocurrencia**, pero la autoridad valora si deberías haber detectado antes.

Con el Digital Omnibus propuesto en noviembre de 2025, este plazo podría ampliarse a 96 horas y consolidarse con otras obligaciones de notificación (NIS2, DORA).

Obligación 4: Derechos de los interesados. Los usuarios tienen derecho a acceder a sus datos, rectificarlos, borrarlos (derecho al olvido), a la portabilidad, a oponerse al tratamiento, a no ser objeto de decisiones automatizadas. Tu producto debe tener mecanismos para atender estas solicitudes en un plazo razonable (generalmente un mes).

Obligación 5: Evaluación de impacto (DPIA). Para tratamientos de alto riesgo (perfilado sistemático, datos sensibles a gran escala, monitorización sistemática), hay que hacer una evaluación de impacto formal antes de empezar. Muchos productos contruidos con IA caen en esta categoría sin que sus creadores lo sepan.

Obligación 6: Privacidad desde el diseño (Privacy by Design). La protección de datos debe estar integrada desde la concepción del producto, no añadida después. Esto tiene implicaciones concretas: pseudonimización por defecto, cifrado en reposo y en tránsito, accesos mínimos, logs protegidos.

Obligación 7: Registro de actividades de tratamiento. Organizaciones con más de 250 empleados, o que traten datos sensibles a gran escala, deben mantener un registro formal de actividades de tratamiento. Para startups es menos crítico operativamente pero cada vez más exigido.

Obligación 8: DPO cuando aplica. Si tratas datos a gran escala, o datos sensibles sistemáticamente, o eres organismo público, necesitas un Delegado de Protección de Datos. Para startups pequeñas no es obligatorio pero es recomendable al menos tener a alguien con la responsabilidad asignada.

Un mensaje importante para cerrar esta sección en clase: el desconocimiento no exime del cumplimiento. Un PM que dice "es que estábamos validando la idea" no tiene excusa jurídica si hay una fuga. La AEPD no acepta "estamos en fase beta" como justificación.

8. A quién afecta: los afectados son los usuarios, no la empresa

Esta familia tiene una inversión mental importante respecto a las anteriores. En credenciales y bases de datos, el afectado principal es la empresa: pierde dinero, sufre reputación, recibe multa. **En datos sensibles, los afectados principales son los usuarios.** La empresa es responsable, pero los sujetos de derecho son los individuos cuyos datos se filtran.

Afectados directos con peso regulatorio:

- **Los usuarios cuyos datos están en la base.** Son los sujetos del RGPD. Tienen derecho a ser informados, a ser indemnizados por daño material y no material, a ejercer sus derechos. No son secundarios; son los protagonistas.
- **La empresa como responsable del tratamiento.** Obligaciones de notificación, de implementación de medidas correctoras, de cooperación con la autoridad, de indemnización.
- **El DPO si existe.** Responsabilidad funcional directa con potencial exposición personal en casos graves.
- **Los directivos.** La tendencia en 2025-2026 apunta a **responsabilidad personal de directivos** en casos de incumplimiento sistémico. La investigación del DPA holandés sobre Clearview AI planteó por primera vez responsabilidad personal de la dirección. DLA Piper predice que esta tendencia se consolidará.

Afectados indirectos:

- **Los contactos de los usuarios afectados.** Si la brecha contiene mensajes, relaciones, emails cruzados, la fuga se propaga a personas que nunca usaron tu producto.
- **Los clientes B2B.** Si tu producto es B2B y expones datos de usuarios finales de tus clientes, hay cadena de responsabilidad. Tus clientes pueden tener sus propias obligaciones de notificación derivadas de la tuya.
- **Los proveedores (data processors).** Bajo RGPD, los procesadores también son directamente responsables. Si un proveedor tuyo sufre una brecha que te afecta, las obligaciones no solo recaen en ellos. DLA Piper reportó múltiples multas directas a procesadores en 2025.

Un aspecto específicamente sensible: los datos de menores. Si tu producto puede ser usado por menores de 16 años (14 en España, según opción nacional), hay obligaciones adicionales. Consentimiento parental verificable, protección reforzada, restricciones de perfilado, restricciones publicitarias. Una brecha con datos de menores se considera **casi automáticamente de alto riesgo** y multiplica la gravedad de cualquier sanción.

9. Casos reales documentados

Caso 1 · Samsung y ChatGPT: el manual del shadow AI (2023)

El caso canónico para explicar el vector de datos sensibles a LLMs externos. Aunque es de 2023, sigue siendo el ejemplo más citado y más útil pedagógicamente.

En marzo de 2023, Samsung levantó la prohibición de uso de ChatGPT para sus ingenieros del área de semiconductores. En menos de 20 días se produjeron **tres incidentes separados** de fuga de información confidencial, todos documentados por The Economist Korea:

Incidente 1: Un ingeniero copió el código fuente de un programa de descarga de la base de datos de medición de instalaciones de Samsung Electronics en ChatGPT para buscar una solución a un bug. El código, que es confidencial, quedó almacenado en los servidores de OpenAI.

Incidente 2: Otro ingeniero introdujo código de programa para identificación de equipos defectuosos en ChatGPT para optimizar el rendimiento. Las secuencias de test para identificar fallos en chips son un secreto industrial de altísimo valor; la optimización de esos procesos puede ahorrar cantidades considerables en tiempo y costes de producción.

Incidente 3: Un tercer empleado convirtió una grabación de una reunión interna a texto usando una herramienta de transcripción, y luego pasó el texto a ChatGPT para generar actas. Los contenidos de esa reunión, que nunca debieron salir de la empresa, quedaron en manos de OpenAI.

Las consecuencias: Samsung implementó un límite de 1.024 bytes por prompt (decisión simbólica más que técnica), abrió investigaciones disciplinarias sobre los tres casos, y emprendió el desarrollo de una IA interna propia para evitar depender de servicios externos. El CEO advirtió públicamente que si volvía a ocurrir, bloquearían completamente el acceso a ChatGPT en la red corporativa.

El dato general que rodea al caso: una investigación paralela de Cyberhaven encontró que **el 3,1% de los usuarios de sus clientes había enviado en algún momento datos corporativos confidenciales a ChatGPT**. Extrapolado a una empresa de 100.000 empleados, eso implica cientos de envíos de datos confidenciales por semana.

Mensaje que este caso permite transmitir en clase: el shadow AI no es un problema de empresas pequeñas descuidadas. Samsung es una de las empresas tecnológicamente más sofisticadas del mundo, con una cultura muy estricta de seguridad. Si les pasó a ellos tres veces en 20 días, le va a pasar a cualquier empresa que no establezca controles explícitos.

Fuentes:

- TechRadar: <https://www.techradar.com/news/samsung-workers-leaked-company-secrets-by-using-chatgpt>
- Cybersecurity Dive: <https://www.cybersecuritydive.com/news/Samsung-Electronics-ChatGPT-leak-data-privacy/647219/>
- Gizmodo (con datos de Cyberhaven): <https://gizmodo.com/chatgpt-ai-samsung-employees-leak-data-1850307376>
- HumanFirewall (análisis pedagógico): <https://humanfirewall.io/case-study-on-samsungs-chatgpt-incident/>

Caso 2 · Las multas RGPD de 2025 (contexto agregado)

No es un caso individual sino el marco de referencia que los PMs deben conocer.

TikTok (ByteDance), 530 millones de euros por la Autoridad Irlandesa de Protección de Datos, en 2025. Motivo: transferencias internacionales ilegales de datos personales a China sin garantías de nivel de protección equivalente.

Apple, 116 millones de dólares por la autoridad italiana en 2025 por violaciones de privacidad del consumidor.

X (ex-Twitter), 120 millones de euros en el primer ejercicio sancionador bajo la Digital Services Act.

El patrón que revela el contexto de 2025:

- Irlanda sigue liderando la enforcement (4.040 millones de euros acumulados desde 2018), principalmente porque es sede europea de las grandes tecnológicas.
- Los enforcement se están diversificando más allá de big tech, hacia servicios financieros, telecomunicaciones, energía y proveedores tecnológicos en general.
- Los procesadores de datos están recibiendo multas directas, no solo los responsables.
- El coste no es solo la multa: las sanciones no pecuniarias (prohibiciones de tratamiento, obligaciones de corrección) pueden ser más costosas operativamente que la multa misma.

Mensaje: el enforcement RGPD no se está desacelerando, se está estabilizando en un nivel alto y se está extendiendo a más sectores. Para un PM que construye productos con datos personales, esto es una constante de riesgo, no una excepción.

Fuentes:

- DLA Piper GDPR Fines and Data Breach Survey 2026:
<https://www.dlapiper.com/en/insights/publications/2026/01/dla-piper-gdpr-fines-and-data-breach-survey-january-2026>
- The Register, análisis del informe:
https://www.theregister.com/2026/01/22/europes_gdpr_cops_dished_out/
- Bitdefender, contexto de enforcement: <https://www.bitdefender.com/en-us/blog/hotforsecurity/europe-tech-sector-eu1-2-billion-fines-gdpr-2025>

Caso 3 · El 54% de brechas en no-producción (contexto estadístico)

Tampoco es un caso individual, sino la estadística agregada que respalda el vector de datos reales en pruebas.

Un estudio de Tonic.ai con 1.000 desarrolladores y empleados de startups encontró que **el 29% de las empresas usan datos de producción sin proteger en entornos de testing**. El **45% reportó haber sufrido una brecha importante en los últimos cinco años debido en parte a datos en entornos inseguros**.

Este dato complementa el que puedes citar de IBM sobre shadow AI: la superficie de exposición de datos personales no está solo en producción; está también en todos los entornos auxiliares donde los datos reales viajan sin protecciones proporcionales.

Fuentes:

- Help Net Security (estudio Tonic.ai): <https://www.helpnetsecurity.com/2022/07/29/real-customer-data-testing-environments/>
- Study Finds: <https://studyfinds.org/cybersecurity-breach-personal-data/>

Caso 4 · Incidentes AI-related en IBM Cost of a Data Breach 2025

Para cerrar con el marco económico agregado:

13% de las organizaciones estudiadas reportaron brechas vinculadas directamente a sus modelos o aplicaciones de IA. Las más comunes:

- Apps y APIs comprometidas en la cadena de suministro de IA (30% de los incidentes de IA).
- Shadow AI (20% de todas las brechas globales).
- Modelos de origen en SaaS de terceros (29% de las brechas de IA).
- Modelos open-source (26%).
- Modelos internos (26%).

El 97% de las brechas de IA ocurrieron en entornos sin controles de acceso adecuados para IA. Este dato es el que más impacta pedagógicamente: no es que la IA sea insegura, es que las organizaciones están desplegándola sin controles.

Fuentes:

- IBM Cost of a Data Breach Report 2025: <https://www.ibm.com/reports/data-breach>
 - IBM Think Insights, análisis CDO: <https://www.ibm.com/think/insights/data-matters/cost-of-a-data-breach>
 - Kiteworks, análisis específico de shadow AI: <https://www.kiteworks.com/cybersecurity-risk-management/ibm-2025-data-breach-report-ai-risks/>
-

10. El factor agente IA: la trampa del "solo estoy probando"

Esta sección es pedagógicamente crítica porque desactiva un razonamiento muy común entre PMs que construyen rápido con Claude Code.

El razonamiento peligroso: "Estoy en fase de prototipo, solo estoy validando si la idea funciona, no tengo usuarios reales todavía, no es para tanto si la seguridad no es perfecta".

Por qué es peligroso:

En primer lugar, porque el RGPD no distingue entre prototipo y producto en producción. En el momento en que un solo usuario real introduce un email real en tu formulario real, ya estás tratando datos personales y todas las obligaciones aplican. No hay un "modo beta" regulatorio.

En segundo lugar, porque los atajos que se toman en fase de prototipo tienden a quedarse. El agente IA optimiza por "que funcione ahora"; no tiene modelo mental de "esto es temporal, lo arreglaremos después". Y el humano que supervisa el agente está enfocado en validar la idea de producto, no en revisar capas defensivas. **El resultado predecible es que el producto escala a producción manteniendo la arquitectura de prototipo.**

En tercer lugar, porque los agentes IA facilitan especialmente tres prácticas que son regulatoriamente arriesgadas:

1. **Logging excesivo.** El agente tiende a añadir logs de debugging con objetos completos. `console.log(user)` o `logger.info(request.body)`. Ese log acaba en producción y registra PII sistemáticamente.
2. **Uso de datos reales para pruebas.** Cuando el PM pide "pruébame que esto funciona con datos reales", el agente coge un snapshot de producción y lo usa en desarrollo. Los datos acaban en el contexto del LLM, en archivos del laptop, en capturas de pantalla enviadas en Slack.
3. **Conexión directa a producción desde desarrollo.** El agente, para que la demo funcione, conecta el entorno de desarrollo a la base de datos de producción. "Ya lo arreglaremos con staging más adelante". Nunca se arregla.

El giro del agente con MCPs. Cuando un PM usa Cursor o Claude Code con un MCP conectado a su base de datos, **el agente tiene acceso potencial a datos personales en tiempo real.** Cada consulta de debug, cada "dame un ejemplo", cada "analiza estos datos" crea una copia del dato en el contexto del LLM. Estos datos viajan al proveedor del LLM. Si el proveedor los retiene (muchos lo hacen por defecto para mejorar el modelo), los datos personales de tus usuarios están ahora fuera de tu control.

El dato duro: según la investigación de Kiteworks citada en IBM 2025, **el 83% de las organizaciones no tienen controles técnicos para detectar o prevenir que empleados suban datos confidenciales a plataformas de IA.** La mayoría de los PMs que construyen con Claude Code están en este 83% sin saberlo.

La solución no es dejar de usar IA. La solución es entender qué datos pueden viajar al LLM y cuáles no, configurar los agentes para que operen sobre datos sintéticos o pseudonimizados en entornos de desarrollo, y revisar los términos de retención de datos de los proveedores de LLMs.

11. Lo que el PM senior tiene que interiorizar

Idea 1: Un email es un dato personal. No necesitas tener nombre, apellidos y DNI para que el RGPD aplique. Cualquier campo que permita identificar indirectamente a una persona (email, IP, user_id, cookie) está protegido. Lista los campos que tu producto recoge y asume que cualquiera de ellos puede ser personal.

Idea 2: El "estoy en beta" no existe regulatoriamente. Desde el primer usuario real, las obligaciones aplican. No hay gracia para MVPs ni para validaciones tempranas. Si vas a recoger datos reales, tienes que cumplir desde el día uno, aunque sea mínimamente: base jurídica declarada, política de privacidad accesible, minimización de campos, cifrado básico.

Idea 3: Los datos reales fuera de producción son la brecha invisible. El 29% de las empresas usa datos reales en testing. El 45% ha tenido brechas por esa razón. Si tu laptop, tu Slack, tu IDE o tu LLM contienen datos reales de usuarios, tienes una superficie de exposición que nadie está protegiendo. Usa datos sintéticos o pseudonimizados para desarrollo.

Idea 4: Lo que le das al agente IA, se lo das al proveedor del agente. Cada consulta con datos reales al LLM es una transferencia de esos datos al proveedor. Revisa las políticas de retención. Configura los agentes para operar sobre datos pseudonimizados. Nunca pegues un dump de producción en el contexto de un LLM externo.

Idea 5: El reloj regulatorio empieza cuando tienes constancia, no cuando ocurre la brecha. Si descubres una brecha un lunes por la mañana, tienes hasta el jueves por la mañana para notificar. Ten un procedimiento mínimo preparado: a quién llamar, qué información reunir, qué formulario de la AEPD usar. Improvisar bajo presión de 72 horas no funciona.

12. Fuentes

Marco regulatorio y multas RGPD:

- DLA Piper GDPR Fines and Data Breach Survey 2026:
<https://www.dlapiper.com/en/insights/publications/2026/01/dla-piper-gdpr-fines-and-data-breach-survey-january-2026>
- DLA Piper, análisis específico del aumento del 22%: <https://www.dlapiper.com/en-us/news/2026/02/personal-data-breaches-in-europe-reach-443-per-day-in-dramatic-22-jump-dla-piper-analysis-reveals>
- The Register, análisis editorial:
https://www.theregister.com/2026/01/22/europes_gdpr_cops_dished_out/
- Bitdefender, contexto europeo 2025: <https://www.bitdefender.com/en-us/blog/hotforsecurity/europe-tech-sector-eu1-2-billion-fines-gdpr-2025>
- CEE Legal Matters, análisis sobre CJEU y daño no patrimonial:
<https://ceelegalmatters.com/briefings/32352-a-record-number-of-personal-data-breaches-were-reported-in-2025>

Datos agregados y costes:

- IBM Cost of a Data Breach Report 2025: <https://www.ibm.com/reports/data-breach>
- IBM Think Insights, análisis para responsables de datos: <https://www.ibm.com/think/insights/data-matters/cost-of-a-data-breach>
- Kiteworks, análisis específico de shadow AI: <https://www.kiteworks.com/cybersecurity-risk-management/ibm-2025-data-breach-report-ai-risks/>
- Axis Intelligence, estadísticas de brechas 2026: <https://axis-intelligence.com/data-breach-statistics-2026-guide/>

Datos en entornos de no-producción:

- Help Net Security (estudio Tonic.ai): <https://www.helpnetsecurity.com/2022/07/29/real-customer-data-testing-environments/>
- Study Finds (análisis del mismo estudio): <https://studyfinds.org/cybersecurity-breach-personal-data/>

Caso Samsung:

- TechRadar: <https://www.techradar.com/news/samsung-workers-leaked-company-secrets-by-using-chatgpt>
- Cybersecurity Dive: <https://www.cybersecuritydive.com/news/Samsung-Electronics-ChatGPT-leak-data-privacy/647219/>
- Gizmodo (con datos de Cyberhaven): <https://gizmodo.com/chatgpt-ai-samsung-employees-leak-data-1850307376>
- HumanFirewall (análisis pedagógico): <https://humanfirewall.io/case-study-on-samsungs-chatgpt-incident/>
- Incident Database AI: <https://incidentdatabase.ai/cite/768/>

Contexto cloud y misconfiguration:

- Bluefire Redteam, estadísticas cloud 2025: <https://bluefire-redteam.com/cloud-security-statistics-2025-misconfigurations-breaches-budgets/>

Fin del documento de Familia 3.

Próximos pasos sugeridos:

- Validar con Jaime que la profundidad y el tono encajan.
- Pasar a la Familia 4 (Entornos, despliegues y configuración) con el mismo nivel de profundidad. Probablemente más corta porque tiene menos volumen de datos agregados y es más operacional.
- Al terminar Familia 4, producir la guía ligera para alumnos integrada con las cuatro familias.